

Lista de Exercícios: TLS

Prof. Gabriel Rodrigues Caldas de Aquino

Compilado em:
November 20, 2025

1 Conceitos: Conexão vs. Sessão

Um diferencial da arquitetura do TLS é a distinção clara entre uma conexão de transporte e uma sessão de segurança.

1. Defina o que é uma **Conexão** no contexto do TLS.
2. Defina o que é uma **Sessão**.
3. Explique a relação entre Conexões e Sessões. É possível que múltiplas conexões seguras pertençam à mesma sessão?
4. Qual é o principal benefício de desempenho (performance) ao se utilizar o conceito de Sessão reutilizável? Por que seria custoso negociar novos parâmetros de segurança para cada nova conexão TCP estabelecida?

2 Arquitetura e Conceitos Fundamentais

O TLS é projetado para prover segurança entre aplicações, permitindo que se comuniquem de forma segura.

1. Diga qual a localização do TLS na pilha de protocolos TCP/IP. Justifique.
2. Do ponto de vista do desenvolvedor da aplicação, como o TLS é percebido em comparação ao TCP padrão?
3. O TLS é composto por um conjunto de protocolos. Descreva o **Protocolo de Registro (Record Protocol)** e a sua função.
4. Quais são as duas camadas do TLS?
5. Cite outros três protocolos de gerenciamento que operam "em cima" do **Protocolo de Registro** e diga qual a função de cada um deles.

3 O Protocolo de Handshake

O Handshake é a parte mais complexa do TLS, responsável pela negociação de parâmetros e autenticação antes da troca de dados.

1. Descreva as Quatro Fases do Handshake.
2. O Handshake ocorre em diferentes fases. Descreva o que é negociado na **Fase 1** através das mensagens `client_hello` e `server_hello`.
3. Na Fase 1, tanto o cliente quanto o servidor geram um valor **Random**. Qual é a importância desse valor para a segurança da conexão ?
4. Explique a função do campo **CipherSuite**.
5. Dado que um cliente se conecta ao servidor, diga qual o motivo de ocorrer a autenticação do servidor durante o handshake.

4 Outros protocolos do TLS

O TLS também possui protocolos para manutenção e sinalização.

1. Qual a finalidade do **Protocolo de Alerta (Alert Protocol)**? Qual é a estrutura da mensagem?
2. O que acontece com a conexão TLS quando **Protocolo de Alerta (Alert Protocol)** apresenta uma mensagem de alerta de nível **fatal**? Dê um exemplo de erro que geraria tal alerta.
3. Diga qual a finalidade do Protocolo **Change Cipher Spec**. O que essa mensagem causa?

5 O Heartbeat

O **Heartbeat** (RFC 6250) possui dois propósitos principais.

1. Explique o propósito de "Keep-Alive".
2. Explique o propósito de "Firewall Traversal" (Evitar Ociosidade).

O **Heartbleed (2014)** foi causado por um erro de programação na biblioteca OpenSSL ao implementar a extensão Heartbeat.

1. Descreva o comportamento esperado do protocolo Heartbeat (o que o servidor deveria fazer ao receber um request).
2. Descreva a falha na vulnerabilidade **Heartbleed (2014)**
3. Explique a falha lógica: O que o servidor OpenSSL deixava de verificar ao processar a mensagem `heartbeat_request`?

4. Como essa falha permitia que um atacante pudesse ler dados sensíveis (como chaves privadas e senhas) da memória do servidor?